

글로벌 CBPR 인증기준(제6조 관련)

1. 개인정보 관리 체계 수립

분야		항목		상세 내용
1.1.	정책 수립	1.1.1	CBPR이행 근거 규정	CBPR의 보호 원칙의 책임있는 준수를 위해 이의 근거가 되는 개인정보보호 관련 내부 지침 또는 법규 등의 준거 규정이 있어야 한다.
1.2.	책임자 지정	1.2.1	개인정보 보호 책임자 지정	CBPR의 보호원칙 준수를 총괄하는 책임자를 지정해야 한다.

2. 개인정보 수집

분야		항목		상세 내용
2.1.	최소 수집	2.1.1	개인정보 수집 경로	개인정보를 수집하는 경로를 쓰시오. 1) 정보주체로부터 직접 수집 2) 수탁사로부터 수집 3) 기타 다른 방법
		2.1.2	개인정보 최소 수집	개인정보 수집 시 수집 목적 달성 또는 목적과 관련된(compatible or related) 범위에 적합한 개인정보만 수집해야 한다.
		2.1.3	합법적 수집	개인정보 수집에 관한 관할 법령과 일관성을 이루고, 합법적이고 공정한 방법으로 개인정보를 수집해야 한다.
2.2.	개인정보 처리방침	2.2.1	개인정보 처리방침 공개	개인정보 처리 방법과 정책에 대한 개인정보처리방침 등을 수립하고 정보주체가 명확히 이해하고 확인하기 쉬운 방법으로 공개해야 한다. 개인정보처리방침에는 다음의 사항이 포함되어야 한다. - 수집하는 개인정보 항목 및 수집 방법 - 개인정보 수집·이용 목적 - (해당하는 경우) 제3자 제공 또는 업무 위탁 사실 및 세부 내용(제공/위탁 목적, 제공/위탁 기관 등) - 기관명, 위치 및 개인정보 보호 담당자 또는 책임자의 연락처 - 정보주체의 개인정보 열람·정정 권리 등 권리 행사 방법
2.3.	수집 시 고지	2.3.1	수집 고지_수집항목	개인정보를 수집하는 시점에 정보주체에게 수집하는 개인정보 항목을 고지해야 한다.
		2.3.2	수집 고지_수집목적	개인정보를 수집하는 시점에 정보주체에게 개인정보의 수집 목적을 고지해야 한다.
		2.3.3	수집 고지_위탁/제공	개인정보를 수집하는 시점에 정보주체에게 개인정

				보를 제3자에게 위탁하여 처리 또는 제공될 수 있음을 고지해야 한다.
		2.3.4	선택권 고지_눈에 띄게 표시	정보주체가 개인정보의 수집, 이용 및 제공에 대한 선택권을 명확하게 인지할 수 있도록 눈에 잘 띄게 표시하여야 한다.
		2.3.5	선택권 고지_쉽게 설명	정보주체가 개인정보의 수집, 이용 및 제공을 제한할 수 있는 선택권에 대해 쉽게 이해할 수 있도록 알기 쉬운 문구로 고지해야 한다.

3. 개인정보 이용/제공/위탁

분야		항목		상세 내용
3.1.	이용	3.1.1	목적 내 이용	개인정보처리방침 등에 고지한 개인정보의 수집 목적 또는 목적과 관련된 범위에 한하여 개인정보를 이용해야 한다.
		3.1.2	목적 외 이용	개인정보를 수집한 목적(또는 목적과 관련된 범위) 외 다른 목적으로 이용하는 경우, 정보주체의 명시적 동의나 다른 법률 근거 등 이에 대한 근거가 있어야 한다.
3.2.	제공/위탁	3.2.1	제공 여부	수집한 개인정보를 다른 개인정보처리자에게 제공하는 경우 제공과 관련한 상세 내용을 기술하시오.
		3.2.2	위탁 여부	수집한 개인정보를 개인정보 수탁사에게 위탁하여 처리하는 경우 위탁과 관련한 상세 내용을 기술하시오.
		3.2.3	목적 내 제공/위탁	개인정보를 제3자에게 제공 또는 위탁하여 처리하는 경우, 이러한 처리가 개인정보의 원래의 수집 목적 달성 또는 이와 관련된 목적을 위한 것이라면, 그 근거를 기술하시오.
		3.2.4	목적 외 제공/위탁	개인정보의 원래의 수집 목적 달성 또는 이와 관련된 목적 범위 외 개인정보를 제3자 제공하거나 위탁하여 처리하는 경우, 그 근거를 기술하시오. 1) 개인의 명시적 동의 2) 개인이 요구한 서비스 또는 제품의 제공을 위해 필요한 경우 3) 다른 법률에 근거한 경우
3.3.	자료 제출 요구 대응	3.3.1	자료 제출 요구 대응	사법기관 또는 정부기관의 개인정보 제공 요청(소환장, 영장, 명령 등)에 대응하기 위한 절차가 마련되어야 한다.

4. 정보주체 권리

분야		항목		상세 내용
4.1.	열람권	4.1.1	개인정보 보유 여부 확인권	정보주체의 요청 시 신청인이 해당인의 개인정보의 처리 여부에 대해 확인해주어야 한다.
		4.1.2	열람권	정보주체의 개인정보 열람 요청 시, 다음의 요건에 따라 열람 처리를 하여야 한다. 1) 정보주체의 본인확인 2) 처리 기한을 정하고 정해진 기한 내 처리 3) 이해하기(읽기) 쉬운 개인정보 파일 형식으로 제공 4) 일반적인 통신/전송 방법(이메일 등) 으로 제공 5) 열람처리에 대한 비용을 청구하는 경우, 청구 사유 및 비용산정 근거 제시
4.2.	정정/삭제권	4.2.1	정정/완성/삭제권	정보주체의 요청 시, 다음의 요건에 따라 개인정보를 정정하거나 완성, 삭제하는 등의 처리를 해야 한다. 1) 정정/완성/삭제 요청 절차를 명확하게 표시 2) 처리 기한을 정하고, 정해진 기한 내 처리 3) 처리 사실 통지 4) 정보주체 요구에 대해 처리 거부 시, 거부 사유 및 거부에 대한 이의 제기할 수 있는 연락처 제공
4.3.	선택권	4.3.1	수집 제한	개인정보 수집에 대해 정보주체가 선택할 수 있는 체계를 마련하여야 한다.
		4.3.2	이용 제한	개인정보 이용에 대해 정보주체가 선택할 수 있는 체계를 마련하여야 한다.
		4.3.3	제3자 제공 제한	개인정보 제3자 제공에 대해 정보주체가 선택할 수 있는 체계를 마련하여야 한다.
		4.3.4	선택권 행사	정보주체가 선택권을 쉽고 (필요 시) 합리적인 비용으로 행사할 수 있도록 방법을 마련해야 한다.
		4.3.5	선택권 조치	정보주체가 선택권 행사 시, 이를 효과적이고 신속하게 조치하기 위한 방법과 절차를 마련해야 한다.
4.4.	민원제기	4.4.1	민원 처리 절차	개인정보 보호 관련 민원을 접수, 조사 및 대응하기 위한 절차를 마련해야 한다.
		4.4.2	민원 처리 기한	접수된 민원에 대해 적절한 기한 내에 조치해야 한다.
		4.4.3	민원 처리	민원 처리를 위한 시정조치 계획이 수립되어야 한다.

5. 무결성

분야		항목		상세 내용
5.1.	최신성 유지	5.1.1	최신성 검증	개인정보 이용 목적에 필요한 범위 내에서 개인정보의 정확하고 완전하며, 최신의 상태 여부를 검증하기 위한 조치를 취해야 한다.
		5.1.2	최신화	개인정보 이용 목적 내 필요한 범위 내에서 부정확, 불완전하거나 오래된 개인정보를 정정하기 위한 절차가 있어야 한다.
5.2.	최신정보 공유	5.2.1	수탁사에 통지	부정확, 불완전하거나 오래된 개인정보가 이용 목적에 영향을 미치고, 수탁사에 정보가 이전된 후 정정이 이루어진 경우, 이러한 정정 사실을 수탁사에게 통지하는 체계를 마련해야 한다.
		5.2.2	제3자에 통지	부정확, 불완전하거나 오래된 개인정보가 이용 목적에 영향을 미치고, 정보의 제3자 제공 이후 정정이 이루어지는 경우, 이러한 정정 사실을 개인정보를 제공받은 자에게 통지하는 체계를 마련해야 한다.
		5.2.3	수탁사로부터 통지	수탁사가 처리하는 개인정보가 부정확, 불완전 또는 최신 상태가 아님을 인지할 때, 수탁사로부터 이를 통지받는 체계를 마련해야 한다.

6. 보호 대책

분야		항목		상세 내용
6.1.	보호대책 수립/이행	6.1.1	보호대책 수립	개인정보 보호를 위한 보호대책을 수립해야 한다.
		6.1.2	보호대책 구현	개인정보의 분실, 불법적인 접근, 파기, 이용, 수정, 제공 또는 기타 오용의 위험으로부터 보호하기 위한 물리적, 기술적 및 관리적 보호대책을 수립하고 구현해야 한다.
		6.1.3	비례적 보호대책	개인정보의 물리적, 기술적 및 관리적 보호대책은 개인정보 침해 위협의 가능성 및 심각도, 개인정보의 민감성, 그리고 개인정보를 처리하는 특성과 비례하는 수준이어야 한다.
		6.1.4	보호대책 이행	비례성의 원칙에 따라 수립된 보호대책을 효과적으로 구현하고 이행해야 한다.
		6.1.5	보호대책 요구사항	내외부 침입, 공격에 의한 개인정보 침해사고를 예방하고 사고 발생 시 체계적으로 대응하기 위한 대책을 수립하고 이행해야 한다.
6.2.	보호대책 평가/개선	6.2.1	보호대책 평가	개인정보 보호대책의 이행 여부, 효과성 등을 평가하기 위한 절차와 방법을 마련하고 정기적으로 실시해야 한다.
		6.2.2	보호대책 개선	개인정보 보호대책에 대한 평가 결과 확인된 문제점에 대해 개선책을 마련하고 보호대책에 반영해야 한다.

6.3.	수탁사의 보호대책	6.3.1	수탁사 보호체계	수탁사가 신청인의 개인정보 보호 정책을 이행하도록 하기 위해 문서화된 체계를 마련해야 한다.
		6.3.2	수탁사 보호대책	위탁처리하는 개인정보의 분실, 불법적인 접근, 파기, 이용, 수정, 제공 또는 기타 오용의 위험으로부터 보호하기 위해 수탁사에게 보호대책 이행을 요구해야 한다.
		6.3.3	수탁사 보호조치 요구사항	수탁사의 개인정보 보호 조치를 위한 요구 사항에는 다음의 사항이 포함되어야 한다. - 신청인의 개인정보보호 정책 및 업무 관행 준수 또는 이와 실질적으로 유사한 수준의 업무 관행 수행 - 신청인의 개인정보 처리 방식과 관련하여 신청인의 지시 사항 준수 - 신청인의 동의 없는 재위탁 제한 - 개인정보 침해 발생 시 신청인에게 통지 요구
		6.3.4	수탁사 관리 · 감독 (자체평가)	수탁사의 개인정보 보호 조치 이행 여부를 주기적으로 점검할 수 있는 체계를 마련해야 한다. - (예) 수탁사에게 주기적 자체평가 실시 및 결과 제출 요구
		6.3.5	수탁사 관리 · 감독 (현장점검)	수탁사의 개인정보 보호 조치 이행 여부를 주기적으로 점검할 수 있는 체계를 마련해야 한다. - (예) 수탁사 대상 정기적 현장점검 또는 모니터링 수행
6.4.	제3자의 보호대책	6.4.1	제3자의 보호조치	개인정보를 제3자에게 제공하나 해당 제3자를 대상으로 CBPR 보호 원칙을 준수를 확인하기 위한 실사 (due diligence)나 합리적인 조치가 어려운 경우에도, 제공된 개인정보에 대한 최소한의 보호 수준을 확인하기 위한 조치를 강구해야 한다.
6.5.	파기	6.5.1	파기	개인정보의 안전한 파기 정책을 마련하고 이행해야 한다.
6.6	임직원 인식제고	6.6.1	임직원 인식제고	임직원을 대상으로 교육훈련 등 개인정보 보호의 중요성에 대한 인식제고를 위한 활동을 실시해야 한다.
		6.6.2	임직원 교육	개인정보 민원 대응을 포함하여 개인정보 보호 정책 및 절차에 대한 직원 교육 절차를 수립하여야 한다.